

Đề cương An toàn bảo mật thông tin

Nội dung ôn tập

- Kiến thức chung về an toàn bảo mật thông tin
- Kiến thức chung về mật mã
- Kiến thức chung về mật mã cổ điển, mật mã hiện đại
- Các hệ mật mã bảng thế như: Ceasar, Vigenere, Vernam và cách mã hóa, giải mã
- Hệ mật mã khóa đối xứng: DES . Các phép biến đổi hoán vị, thay thế. Chế độ mã hóa khối ECB, CBC và Counter
- Hệ mật mã khóa công khai: RSA. Các phép mã hóa, giải mã dựa trên phép toán mod
- Chữ ký số: sơ đồ và ứng dụng. Chứng chỉ số

Kiểm tra giữa kỳ

- Trắc nghiệm: 45 -> 50 câu
- Nội dung của 4 chương đầu : Tổng quan về ATBMTT, tổng quan Mật mã, Hệ mật mã khóa đối xứng , Hệ mật mã khóa công khai
- Dạng câu hỏi
 - Trắc nghiệm chọn 1 đáp án
 - Trắc nghiệm chọn 1 hoặc nhiều đáp án
 - Sắp xếp các phương án theo thứ tự
 - Điền kết quả vào ô trống

Chương 1 – Tổng quan về ATBM TT

- An toàn bảo mật thông tin là gì ? Vai trò, tầm quan trọng trong hoàn cảnh hiện tại. Nguyên nhân và sự phát triển.
- Nhận thức về ATTT, thực hiện ATTT từ các góc độ khác nhau.
- Đối tượng, mục tiêu của an toàn bảo mật thông tin. Các yêu cầu đặt ra và biện pháp tổng thể
- Quy trình xây dựng giải pháp đảm bảo ATTT

- Mỗi nguy cơ (threat), rủi ro (risk), chính sách (policy), cơ chế điều khiển (control) bao gồm thủ tục và giải pháp kỹ thuật
- Đánh giá mức độ an toàn và cân bằng giữa các tiêu chí khác nhau khi xây dựng giải pháp ATTT
- ATTT trải rộng trên nhiều lĩnh vực từ quản trị tổ chức, quản trị rủi ro đến các lĩnh vực kỹ thuật của CNTT như An ninh mạng và phát triển phần mềm an toàn

- Đặc điểm và kỹ thuật của mật mã cổ điển
- Mật mã Ceasar
 - Cách mã hóa và giải mã Ceasar sử dụng 1 bảng thế
- Mật mã Virgine
 - Cách mã hóa và giải mã Vigenere sử dụng nhiều bảng thế (tối đa 26 bảng)
- Mật mã Vernam
 - Mã hóa kí tự
 - Mã hóa bit nhị phân

Chương 2 - Tổng quan về mật mã

- Mật mã là gì ? Tại sao mật mã lại là một trong các cơ chế nền tảng của bảo vệ an toàn thông tin
- Sơ đồ truyền tin bảo mật, các khái niệm cơ bản trong mật mã
- Vấn đề thám mã và độ an toàn của mật mã
- Các hệ mật mã
- Ứng dụng nói chung của mật mã
- Tại sao phân chia mật mã cổ điển và mật mã hiện đại. Phân biệt

Chương 3 - Mật mã khóa đối xứng

- Đặc trưng của mật mã khóa đối xứng, vấn đề về khóa
- Mã hóa khối (block cipher), phân biệt với mã hóa dòng (stream cipher).
 - Nguyên lý thiết kế và kỹ thuật sử dụng trong mã hóa khối
- Hệ mật mã DES:
 - Sơ đồ nguyên lý
 - Quá trình sinh khóa con
 - Hàm F biến đổi dữ liệu tại mỗi vòng,
 - Các S-box sử dụng để thay thế dữ liệu

Chương 4 – Mật mã khóa công khai

- Độ an toàn của hệ mật mã DES.
 - Tại sao hiện nay DES không được coi là an toàn.
 - Có cách nào để cải tiến DES, mức độ an toàn tăng lên như thế nào.
 - Hệ mật mã nào ngày nay đang được dùng thay cho DES
- Các chế độ mã hóa khối ECB, CBC, Counter. Ưu nhược điểm của các chế độ đó

- Hoàn cảnh ra đời
- Đặc điểm của mật mã khóa công khai, phân biệt với mật mã khóa đối xứng
- Đặc trưng của khóa và nguyên tắc thiết kế
- Hệ mật mã RSA: bài toán cơ sở RSA, công thức mã hóa và giải mã, cách sinh khóa
- Cách chọn khóa và tính nhanh modulo của lũy thừa

- Ứng dụng RSA trong bảo mật truyền tin, đánh giá độ an toàn
- Chữ ký điện tử là gì, đặc điểm và phân biệt với chữ ký tay.
- Sơ đồ chữ ký điện tử sử dụng mật mã RSA
- Đặc điểm và tác dụng của hàm băm mật mã
- Kết hợp hàm băm và chữ ký điện tử.

- Quản lý khóa: áp dụng mật mã công khai RSA để chia sẻ khóa phiên (đối xứng) trong 1 phiên truyền dữ liệu
- Vấn đề chứng nhận khóa công khai và chứng chỉ số
- Khái niệm, các phân phối, quản lý và kiểm tra chứng chỉ số

Các dạng câu hỏi cần tính toán

- Chủ yếu về nội dung Mật mã
 - Mã hóa và giải mã Ceasar
 - Mã hóa và giải mã Vigenere
 - Mã hóa và giải mã Vernam
 - Biến đổi dữ liệu trong thuật toán DES
 - Tính toán modulo lũy thừa theo công thức của mật mã RSA

Thi cuối học kỳ

- Trắc nghiệm: 45 -> 50 câu
 - Nội dung của 4 chương đầu : khoảng 30% câu hỏi
 - Nội dung của 3 chương sau: khoảng 70% câu hỏi
- Dạng câu hỏi
 - Trắc nghiệm chọn 1 đáp án
 - Trắc nghiệm chọn 1 hoặc nhiều đáp án
 - Sắp xếp các phương án theo thứ tự
 - Điền kết quả vào ô trống
 - Case study: 1 tình huống đề bài cho nhiều câu hỏi trắc nghiệm

Nội dung ôn tập

- Kiến thức chung về an toàn bảo mật thông tin
- Kiến thức chung về mật mã
- Kiến thức chung về mật mã cổ điển, mật mã hiện đại
- Các hệ mật mã bảng thế như: Ceasar, Vigenere, Vernam và cách mã hóa, giải mã
- Hệ mật mã khóa đối xứng: DES . Các phép biến đổi hoán vị, thay thế. Chế độ mã hóa khối ECB, CBC và Counter
- Hệ mật mã khóa công khai: RSA. Các phép mã hóa, giải mã dựa trên phép toán mod
- Chữ ký số: sơ đồ và ứng dụng. Chứng chỉ số

- Xác thực: định nghĩa cơ chế xác thực, phân loại, cơ sở để xác thực.
 - Xác thực sinh trắc
 - Xác thực bằng mật khẩu: sơ đồ xác thực, các dạng tấn công và sơ đồ cải tiến với sự tham gia của hàm băm mật mã
 - Xác thực bằng mật mã khóa công khai
- Điều khiển truy nhập: định nghĩa cơ chế, phân loại các mô hình điều khiển truy nhập
- Mô hình điều khiển truy nhập theo phân quyền tự do (DAC)
- Mô hình điều khiển truy nhập theo quy tắc (MAC)

Chương 5 – Xác thực

- Cơ chế xác thực, phân loại
- Xác thực danh tính bằng sinh trắc
 - Xác thực vân tay: cơ sở bằng chứng, ưu nhược điểm
 - Xác thực võng mạc mắt: cơ sở bằng chứng, ưu nhược điểm
- Xác thực mật khẩu
 - Lược đồ cơ bản
 - Các dạng tấn công
 - Lược đồ cải tiến chống replay attack
 - Cơ chế challenge-response

Chương 6 – Mô hình điều khiển truy nhập DAC

- Khái niệm về điều khiển truy nhập
- Mô hình DAC
 - Ma trận truy nhập Access Matrix
 - Các cách cài đặt Ma trận truy nhập: bộ ba SOP, khả năng truy nhập và danh sách điều khiển truy nhập ACL; ứng dụng trong các hệ thống thực tế
 - Chuyển giao và cấp quyền truy nhập
 - Mô hình HRU: mô tả, cú pháp lệnh HRU và áp dụng vào việc cấp quyền, chuyển giao quyền
 - Hạn chế của mô hình DAC, ví dụ trojan horse tấn công

Chương 7 – Mô hình điều khiển truy nhập MAC

- Đặc điểm mô hình MAC
 - Khái niệm về tập hợp có thứ tự
- Mô hình BLP
 - Mô tả
 - Hai quy tắc
 - Tác dụng của mô hình, ví dụ trong ngăn chặn trojan horse
- Mô hình Biba
 - Mô tả
 - Hai quy tắc
 - Tác dụng và ví dụ trong ngăn chặn trojan horse

- Mô hình Lattice của Denning
 - Phân lớp bảo mật
 - Khái niệm về luồng thông tin và chính sách luồng thông tin
 - Mô tả mô hình bằng bộ ba SC, $\rightarrow$, +
 - 4 tiên đề Denning
 - Mô hình điều khiển truy nhập Lattice 1 nhánh, nhiều nhánh. Quy tắc đọc và ghi dữ liệu theo chiều của luồng thông tin
 - Các thao tác trên mô hình Lattice, kết hợp 2 lattice tạo thành lattice mới
 - So sánh BLP, Biba và Lattice. Ví dụ về kết hợp BLP và Biba

Một số dạng câu hỏi

- Câu hỏi tính toán liên quan đến Mật mã
- Câu hỏi tình huống: Cho trước một mô hình điều khiển truy nhập hoặc các yêu cầu về phân quyền, cần
 - Xác định quyền truy nhập
 - Gán quyền hoặc mức độ cho chủ thể và đối tượng
 - Cấp, chuyển giao quyền / Biến đổi mô hình để đạt được các tiêu chí đề ra
- Câu hỏi tình huống: Cho trước lược đồ xác thực hoặc yêu cầu đặt ra cho xác thực
 - Hoàn thành lược đồ
 - Chọn các kỹ thuật cần thiết để đạt độ an toàn